

When It Happens: Detection, Containment, Response & Recovery

CS 474 — Computer Security · Class 6 · Thursday, October 29, 2026 · Hour 1 — 60 minutes, five lessons

Cyber.SoHo Educational Hub — From the Industry to the Classroom — Building the IT's Future, Today and Together !

Educational material — Cyber.SoHo / Asen Grozdanov · © 2026 Cyber.SoHo · Legal Notice, Terms of Use and Acceptable Use Policy: https://cyber-soho.github.io/prevmon/00.01.%20cyber.soho%20-%20legal.html

Before we start — the rules of every lab

- Educational material — Cyber.SoHo / Asen Grozdanov · © 2026 Cyber.SoHo — licensed to you personally (Legal Notice §4.2)
- No copying, posting or sharing; no use as training data for any machine-learning system (§4.3)
- Authorization governs everything: scanning, testing or a denial-of-service “test” against any system you do not own is an offence (Criminal Code s. 342.1; §8)
- Everything today runs on the fictional BlueFern Trading Inc. and inside your browser — no packets are sent
- Course exercises are not forensic work; a real incident at your job follows your employer's plan (§7.8)
- Links and videos were checked on October 25, 2026; check any link with VirusTotal before clicking (Annex C)
- Full text: https://cyber-soho.github.io/prevmon/00.01.%20cyber.soho%20-%20legal.html

Today: four questions, five lessons

- How do we find out that something is wrong? → Lesson 1 — Detection (11 + 3 min)
- Which attack is detected by counting packets? → Lesson 2 — Denial of service (8 + 3 min)
- What do we do in the first hour, and after? → Lesson 3 — The incident-response lifecycle (12 + 4 min)
- How do we get the business back? → Lesson 4 — Backups, **RPO** (Recovery Point Objective), **RTO** (Recovery Time Objective) (5 + 2 min)
- Which protection is worth paying for? → Lesson 5 — Risk arithmetic (7 + 5 min)
- Applied to BlueFern Trading Inc.: the untested **USB** (Universal Serial Bus) drive, the shared password, the $25,000-per-hour web shop, the $500,000 customer database
- Hours 2–3: tabletop incident · risk register · backup plan → Binder Part 6, due Wed Nov 4, 23:59

By the end of this hour you will be able to

- Define a log, explain why logs are centralized, and distinguish **IDS** (Intrusion Detection System) from **IPS** (Intrusion Prevention System), signature from anomaly detection, a server from a honeypot
- Recognize a **DoS** (Denial of Service) / **DDoS** (Distributed Denial of Service) attack from its symptoms — the **SYN** (synchronize flag of a TCP segment) flood in particular — and name the three mitigation families
- List the phases of the **NIST** (National Institute of Standards and Technology) **SP** (Special Publication) 800-61 lifecycle in order, assign an action to its phase, and say what is preserved and who is informed
- Design a backup scheme that satisfies the 3-2-1 rule, and compute the **RPO** (Recovery Point Objective) and the **RTO** (Recovery Time Objective) of a system
- Compute **SLE** (Single Loss Expectancy) = **AV** (Asset Value) × **EF** (Exposure Factor) and **ALE** (Annualized Loss Expectancy) = **SLE** × **ARO** (Annualized Rate of Occurrence), compare the **ALE** with and without a control, and decide whether the control is worth it (**LO** — Learning Outcome 5)
- The one FACT: your weekly work IS the project, the project IS your exam preparation — Binder Part 6 due Wednesday, November 4, 23:59



Lesson 1 — Detection

Logs · log centralization and **SIEM** · **IDS** vs **IPS** · signature vs anomaly · honeypots — 11 minutes + 3-minute visualization

1.1 What a log is — five fields in one line

- A log entry is a time-stamped record of an event; the file or database that collects them is the log
- Five questions: when (timestamp) · where (host) · what (event) · who (user, process, **IP** address) · outcome
- Oct 27 08:01:12 shop sshd[2231]: Failed password for root from 198.51.100.77 port 51022 ssh2
    - when 08:01:12 · where shop · what sshd login · who root from 198.51.100.77 · outcome failed
- Almost every attack leaves a trace in a log before it does damage: password guessing, port scans, web attacks
- Detection = turning those traces into an alert a human looks at — **NIST** (National Institute of Standards and Technology) **SP** (Special Publication) 800-92, Guide to Computer Security Log Management

1.2 Why logs are centralized — the SIEM idea

- An attacker who controls the host can delete its local log → send a copy of every entry, as written, to a separate hardened collector
- Retention period: months or years, so late-discovered incidents can still be investigated
- Three more benefits: correlation across sources · one time base (**NTP** — Network Time Protocol) · search and alerting over everything
- **SIEM** (Security Information and Event Management) = Security Information and Event Management: collect → normalize → store → correlate → alert
- Correlation rule example: “ten failed logins from one address within sixty seconds”
- Large company: a **SOC** (Security Operations Centre) watches the dashboard · BlueFern: two IT staff, an open-source **SIEM** (Wazuh) or the cloud provider's logging, alerts by e-mail
- The size changes; the five steps do not

1.3 Intrusion detection and intrusion prevention

- **IDS** (Intrusion Detection System) (**NIST** — National Institute of Standards and Technology **SP** 800-94): monitors network traffic or host activity for signs of an attack and produces an alert
- Network-based (**NIDS** — Network-based Intrusion Detection System): a copy of a segment's traffic from a mirror port or a tap — Snort, Suricata, Zeek
- Host-based (**HIDS** — Host-based Intrusion Detection System): runs on one machine, watches processes, files and its own logs — Wazuh / OSSEC
- **IPS** (Intrusion Prevention System) = the same system placed inline: traffic passes through it, so it can drop the offending packets
- The whole distinction: beside the traffic (alert) versus in its path (block)
- Cost of inline: a failure or a misjudged request stops real traffic → detect first, tune for weeks, then switch selected rules to prevention

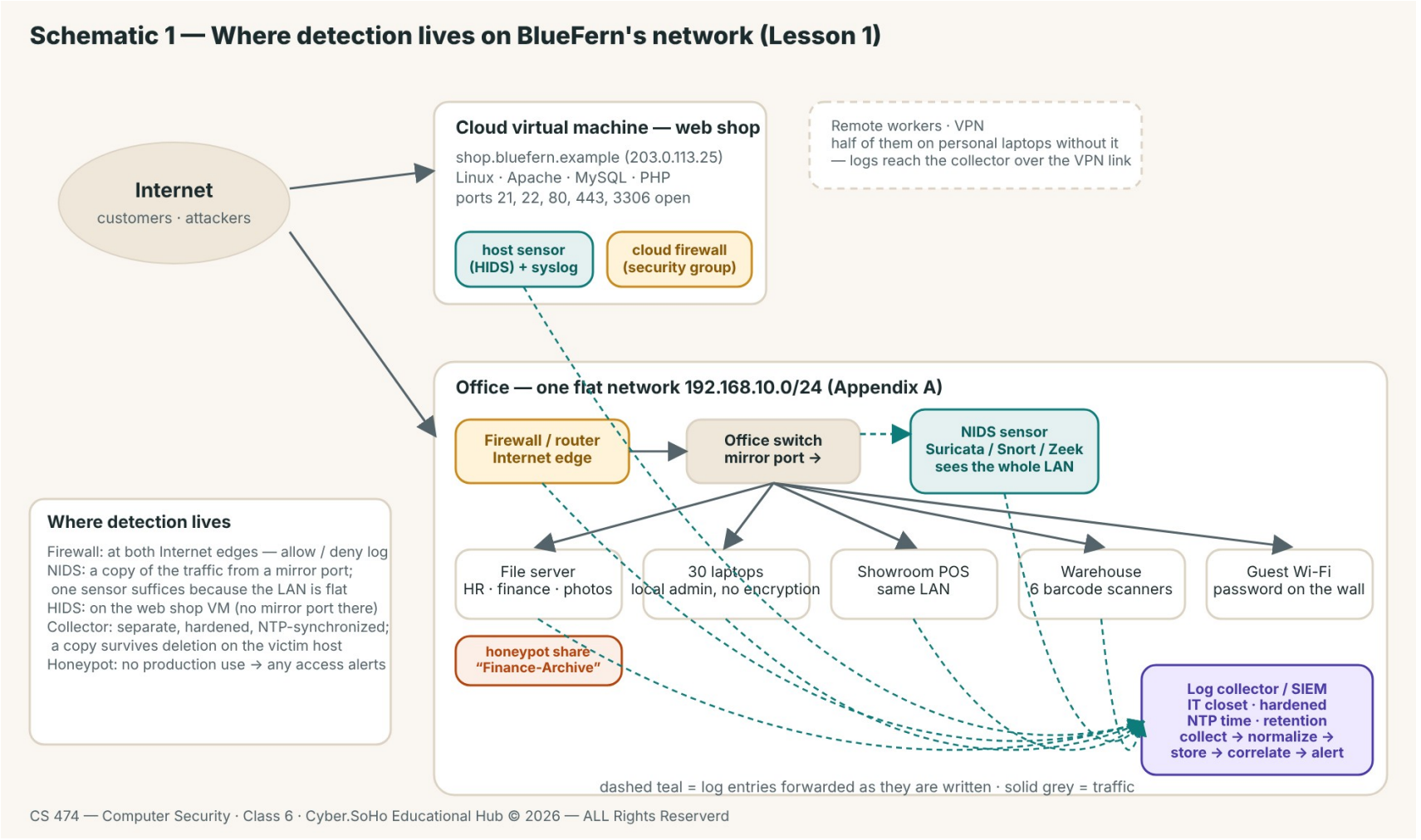
1.4 Signature, anomaly, protocol analysis — knowing what normal looks like

- Signature-based: compare with known attack patterns (a byte sequence, “' OR '1'='1”, a login sequence) — precise, explains itself, misses unknown attacks
- Anomaly-based: learn a baseline of normal volume, hours, protocols, then flag significant deviations — finds new attacks, alerts on legitimate change
  - BlueFern's Black Friday at 20× normal looks like an attack to a system that only ever saw October
- Stateful protocol analysis: the system knows how a protocol must behave and flags conversations that break the rules
- False positive: an alert without an attack (costs analyst time; blocks users in an **IPS**)
- False negative: an attack without an alert (costs the company the incident)
- Tuning = lowering both at once; first question on a new network: what does normal look like here?

1.5 Honeypots

- A computer, service, account or file with no production purpose — it exists only to be touched by an intruder
- No legitimate user ever needs it → any interaction is suspicious by definition → almost no false positives
- Honeytokens: a fake “Finance-Archive” share, a fake administrator account, a decoy database row
- They also record the intruder's tools and methods → better signatures for the real detection systems
- Two rules: isolate it (no stepping stone into real systems) · never put real data in it
- The Honeynet Project (non-profit) publishes free honeypot software and analyses

Schematic 1 — Where detection lives on BlueFern's network

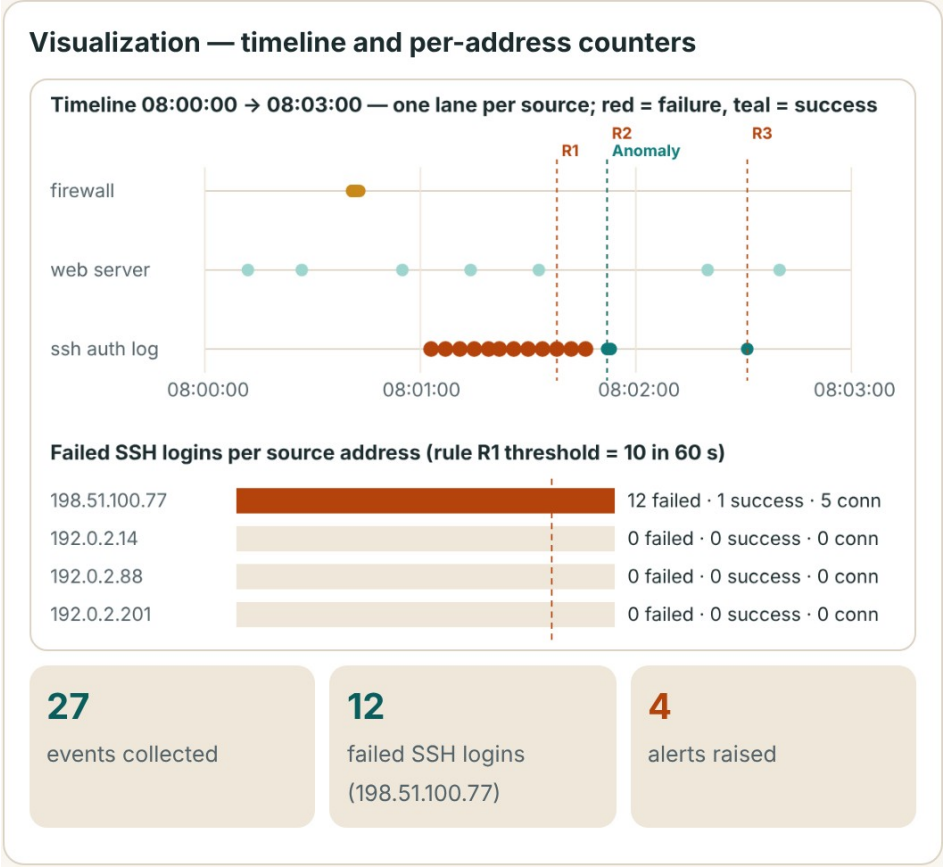


Micro-activity 1 — Place the sensors (3 min)

- On the Part 2 network map of BlueFern: Internet → cloud web shop · office router → flat **LAN** (Local Area Network) 192.168.10.0/24 (file server, 30 laptops, showroom **POS**, warehouse scanners) · guest Wi-Fi · **VPN** (Virtual Private Network)
- Place: a firewall · an **IDS** (Intrusion Detection System) sensor · a log collector · a honeypot
- For each: one sentence — why there?
- Expected: the flat network makes one sensor sufficient (and is a weakness for defence); segmentation comes in Class 10

Example 1 — Three logs, one attacker

- Task: centralize, normalize and correlate three BlueFern logs — cloud firewall, Apache access log, **SSH** (Secure Shell) auth log
- 08:00:41 port scan on 21, 22, 80, 443, 3306 — all allowed
- 08:01:03 → 08:01:46 twelve “Failed password for root” from 198.51.100.77
- 08:01:52 “Accepted password for root” — then a new account svc_backup
- Rules: R1 ≥ 10 failures in 60 s (high) · R2 success after ≥ 5 failures (critical) · R3 account after a critical alert · baseline: address never seen
- Deliverable: normalized event table + alert card → the detection evidence of Exercise 6.1; sensor and collector placement → Class 10



Lesson 1 — flash-cards and formative quiz

- FORMATIVE, NOT SUMMATIVE — practice only; nothing is recorded; it does not count toward your grade
- Q1 (**MCQ** — Multiple-Choice Question — one correct answer) — Which statement correctly describes the difference between an **IDS** (Intrusion Detection System) and an **IPS** (Intrusion Prevention System)?
- Q2 (**MCQ**) — An attacker gains root on BlueFern's web shop and deletes /var/log/auth.log. Which practice would have preserved the evidence?
- Q3 (**MCQ**) — A rule that alerts whenever an **HTTP** (Hypertext Transfer Protocol) request contains the string ' OR '1'='1 is an example of:
- Q4 (**MCQ**) — On Black Friday an anomaly-based system raised forty alerts because traffic was twenty times the October baseline. No attack took place. The forty …
- Q5 (**MSQ** — Multiple-Select Question — several correct answers · select 3) — Which of the following are benefits of centralizing logs in a collector or **SIEM** (Security Information and Event Management)?
- Q6 (**MSQ** · select 2) — Which statements about honeypots are correct?
- Flash-cards: five click-to-flip cards in the module — What is a log entry, and which five questions does it answer… · **IDS** versus **IPS** — what is the one difference? · Signature-based versus anomaly-based detection.



Lesson 2 — Denial of Service and DDoS

SYN floods · amplification · botnets · detection signs · mitigations — 8 minutes + 3-minute practical

2.1 What a denial-of-service attack is

- An attack on availability: exhaust a resource the service needs — bandwidth, the connection table, processor and memory, application capacity
- Nothing is stolen or modified; the service is simply not there
- BlueFern's price: $3,000 per hour on a normal day, $25,000 per hour during Black Friday week
- **DDoS** (Distributed Denial of Service) = the same attack from many machines — a botnet of infected computers, routers and cameras steered from a **C2** (command-and-control) server
- The operator owns no bandwidth; the victims' devices supply it (Mirai, 2016: factory passwords → floods above 1 Tbit/s)

2.2 The SYN flood — an attack on the handshake

- **TCP** (Transmission Control Protocol) handshake: **SYN** (synchronize flag of a TCP segment) → **SYN-ACK** (synchronize-acknowledge reply of a TCP server) → **ACK** (acknowledge flag of a TCP segment); between 1 and 3 the server stores a half-open entry in a table of fixed size (the backlog)
- **SYN** flood: a stream of SYNs with forged (spoofed) source addresses — SYN-ACKs go nowhere, the **ACK** never comes
- Each forged **SYN** occupies an entry until its timer expires; table full → the real customer's **SYN** is dropped
- The link may be almost idle: a state-exhaustion attack, not a volumetric one — **RFC** (Request for Comments — an Internet standards document) 4987
- **SYN** cookie: the server encodes the state in the **SYN-ACK** sequence number and stores nothing; the entry is created only when a valid **ACK** returns
- A forged **SYN** then costs one reply and no memory

2.3 Volumetric attacks, amplification, application floods

- Volumetric: more bytes per second than the victim's link carries
- Reflection with amplification: small forged requests to public servers (open **DNS** resolvers, **NTP**, memcached) → large answers sent to the victim
- **CISA** (Cybersecurity and Infrastructure Security Agency (United States))'s measured factors: **DNS** (Domain Name System) ≈ 28–54×, **NTP** (Network Time Protocol) monlist ≈ 557×, memcached up to tens of thousands ×
- Application-layer flood: few packets, many expensive requests (search, login, report) — each costs a database query
- Small in bytes and shaped like real users → the hardest to tell apart from a busy day

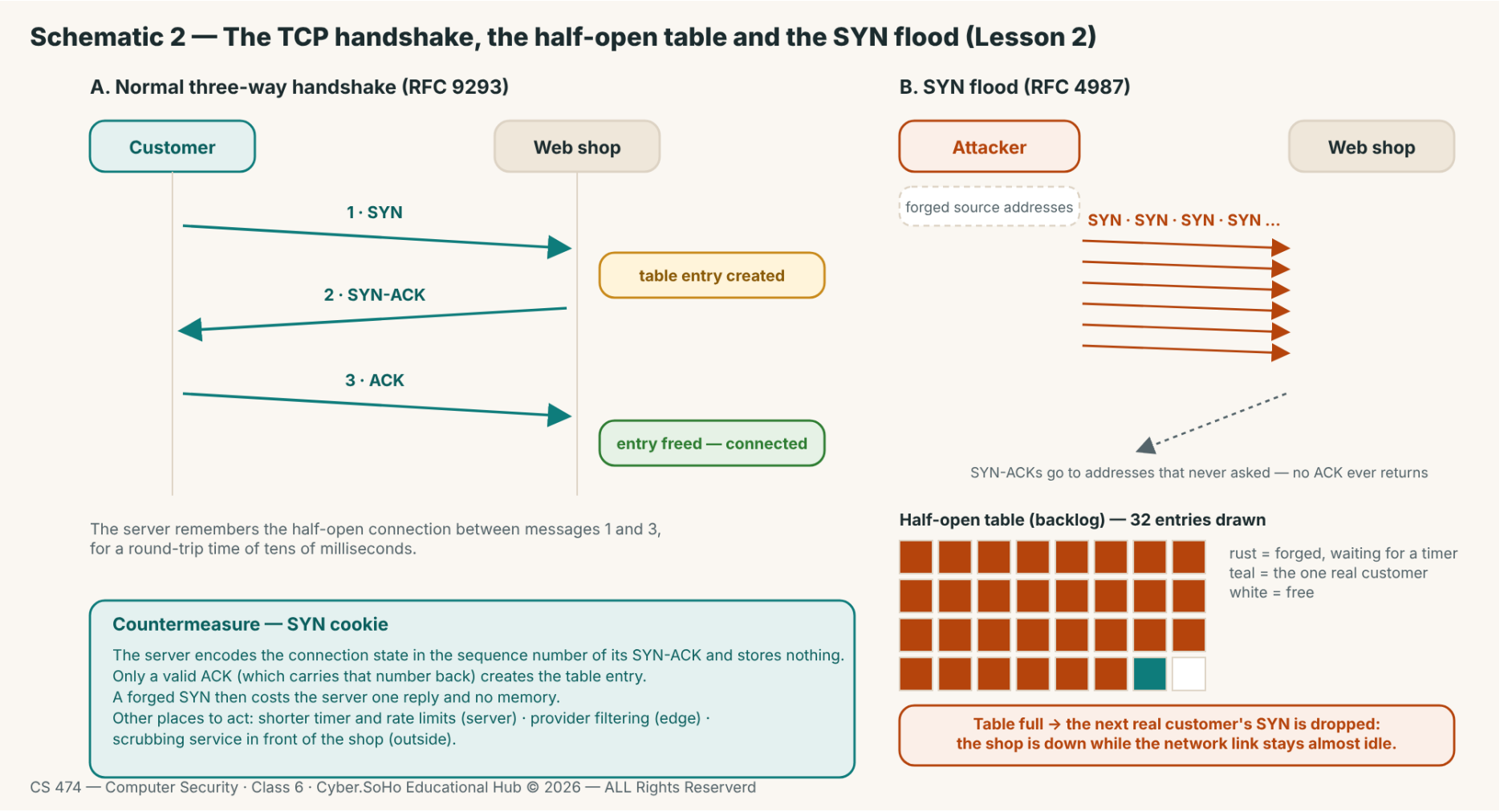
2.4 Detection signs — a flood versus Black Friday

- **SYN** (synchronize flag of a TCP segment) flood: **SYN** count far above completed handshakes · half-open table full (SYN_RECV) · random sources that never reappear
- Volumetric: saturated link; the upstream provider calls
- Application flood: the same few URLs at a machine's pace from addresses that never load an image or a style sheet
- A real Black-Friday surge: handshakes complete · visitors browse many pages and buy · gradual growth · matches the marketing calendar
- You cannot say “twenty times normal” without having measured normal — the baseline of Lesson 1

2.5 Mitigations — three places to act

- On the server: **SYN** (synchronize flag of a TCP segment) cookies · shorter half-open timers · connection limits per source · rate limiting of expensive requests
- At the network edge: firewall rules; the provider's upstream filtering; ingress filtering that stops forged addresses at their source
- Outside the company: a **CDN** (Content Delivery Network) or scrubbing service — many data centres, capacity no small retailer owns, only cleaned traffic forwarded
- For BlueFern's single **VM** (Virtual Machine) the honest answer is the third: rent a front door that can absorb a botnet
- Organizational step (Canadian Centre for Cyber Security, **ITSAP**.80.100): know your provider's emergency number before you need it
- Never test a denial of service against any system without written authorization — an offence in itself

Schematic 2 — The handshake, the half-open table and the SYN flood

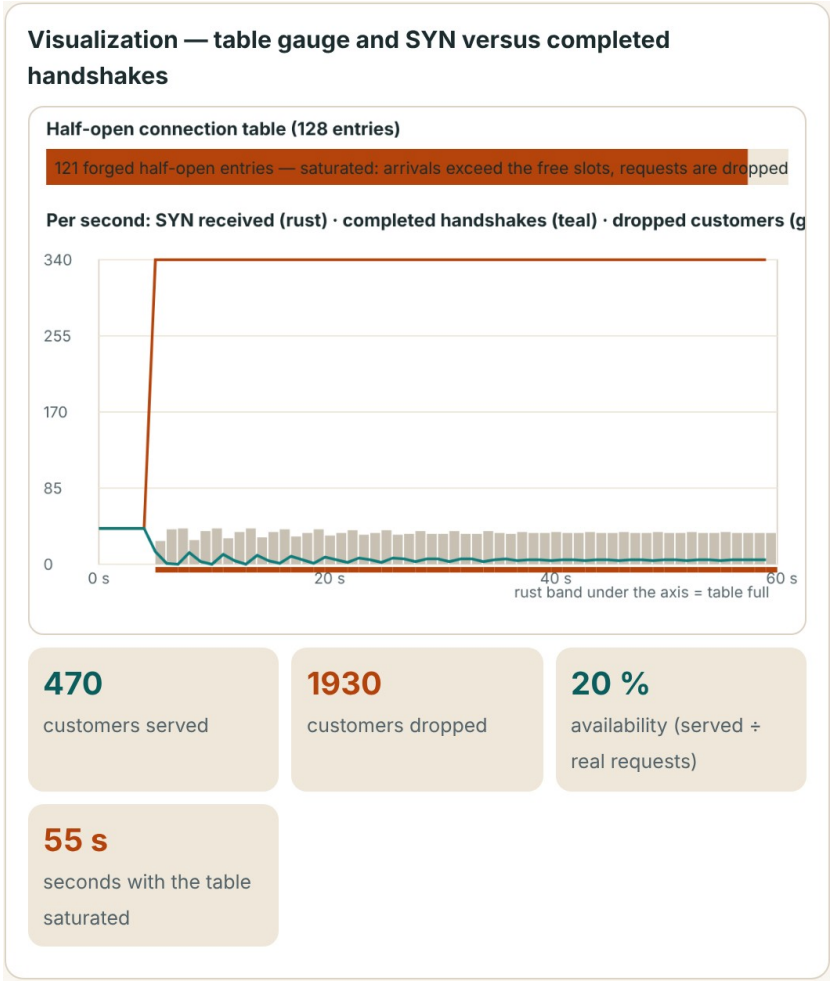


Micro-activity 2 — Read a packet-capture summary (3 min)

- 60 seconds on the web shop's link:
  - **SYN** (synchronize flag of a TCP segment) received: 48,212 from 31,900 distinct source addresses
  - **SYN-ACK** (synchronize-acknowledge reply of a TCP server) sent: 48,212 · **ACK** (acknowledge flag of a TCP segment) received: 212
  - connections in SYN_RECV: 1,024 (table full)
  - completed **HTTP** (Hypertext Transfer Protocol) requests: 190 (October average: 2,400 per minute)
- Name the attack, and one mitigation at each of the three places

Example 2 — Black Friday or SYN flood?

- Task: the web shop's table of 128 half-open entries, second by second, under a Black-Friday surge and under a 300 **SYN** (synchronize flag of a TCP segment)/s forged flood
- Surge (800 real requests/s): the table fills and drains; the shop slows but serves
- Flood: after 3 s the table is full; ~35 of 40 real customers per second are dropped; the link carries 0.2 Mbit/s
- Mitigations: **SYN** cookies → nothing stored before the **ACK** (acknowledge flag of a TCP segment) · rate limit → no effect on forged addresses · scrubbing → 90 % filtered
- Deliverable: indicators table + mitigation comparison → **DoS** (Denial of Service) row of Exercise 6.2, web-shop **RTO** (Recovery Time Objective) in 6.3, **CDN** (Content Delivery Network) / **WAF** (Web Application Firewall) in Class 10



Lesson 2 — flash-cards and formative quiz

- FORMATIVE, NOT SUMMATIVE — practice only; nothing is recorded; it does not count toward your grade
- Q1 (**MCQ** — Multiple-Choice Question — one correct answer) — During a **SYN** (synchronize flag of a TCP segment) flood the web shop's network link is almost idle, yet customers cannot connect. Which resource is exhausted?
- Q2 (**MCQ**) — Why does a **SYN** cookie defeat a spoofed **SYN** flood?
- Q3 (**MCQ**) — A capture shows the same two URLs — the search page and the login page — requested 900 times per minute from addresses that never load an image or …
- Q4 (**MCQ**) — Which observation distinguishes a legitimate Black-Friday surge from a **DDoS** (Distributed Denial of Service) attack?
- Q5 (**MSQ** — Multiple-Select Question — several correct answers · select 3) — Which of the following are detection signs of a **SYN** flood?
- Q6 (**MSQ** · select 2) — BlueFern wants to protect its single-VM web shop against **DDoS**. Which measures act OUTSIDE the server itself?
- Flash-cards: five click-to-flip cards in the module — Which security property does a denial-of-service attack viol… · Explain the **SYN** flood in three sentences. · What is a **SYN** cookie?



Lesson 3 — The incident-response lifecycle

NIST SP 800-61 · phases · roles · evidence preservation · communication — 12 minutes + 4-minute flash-cards and quiz

3.1 Event, incident, and why a lifecycle exists

- Event: any observable occurrence in a system or network · adverse event: one with a negative consequence
- Incident: a violation, or imminent threat of violation, of security policies, acceptable-use policies or standard practices (**NIST** — National Institute of Standards and Technology **SP** 800-61)
- The first hour is the worst moment to invent a procedure: stress, incomplete information, wrong reflexes (power off, restore now, tell everybody)
- Rev. 2 (2012): preparation · detection & analysis · containment, eradication & recovery · post-incident activity
- Rev. 3 (April 2025): the same work inside the **CSF** (Cybersecurity Framework) 2.0 functions — Govern, Identify, Protect, Detect, Respond, Recover; use the model that suits you
- This course: five steps, containment named separately — the steps the Canadian Centre for Cyber Security lists in **ITSAP** (IT Security Awareness Publication of the Canadian Centre for Cyber Security).40.003
- Two loops back: containment → analysis; lessons learned → next preparation

3.2 Preparation — while nothing is happening

- A written incident response plan: who is on the team, how they are reached at 02:00 (printed list), the out-of-band channel, who may take a system offline, who talks outside
- Logging and detection in place (Lesson 1) — without logs there is nothing to analyse
- A jump kit: clean laptop, disk images, spare hardware, write-blockers, copy tools
- Rehearsal: a tabletop exercise is the cheapest way to find that the plan names someone who left a year ago
- BlueFern: no plan, no team, no training — an empty preparation phase that every later phase pays for
- Exercise 6.1 this afternoon is a tabletop

3.3 Detection and analysis — from alert to confirmed incident

- Precursors (an incident may occur: a scan, a vulnerability announcement) and indicators (one is occurring: alert, ransom note, complaint)
- Three questions: is it real? what is its scope? how bad is it?
- Triage: compare the indicator with the firewall log, the **SIEM** (Security Information and Event Management) timeline, the state of the machine
- Prioritization (**SP** — Special Publication 800-61): functional impact · information impact · recoverability
- Documentation starts now: the incident timeline opens at the first alert and closes with the report
- Your decision log in Exercise 6.1 is that document

3.4 Containment — stop the damage, keep the evidence

- Short-term: disconnect the machine, disable the account, block the address, take the shop offline if it is the source of the leak
- Long-term: keep the business running while the clean rebuild is prepared — a temporary server, restricted access
- Four decision criteria: potential damage · evidence to preserve · service availability · time and resources
- ISOLATE, DO NOT POWER OFF — the network cable stops the attacker; the power cable destroys memory (processes, connections, the ransomware's key, the attacker's tools)
- Evidence preservation: capture memory and copy the disk before changing anything · work on copies · **SHA-256** (Secure Hash Algorithm with a 256-bit digest) every copy · chain of custody · originals untouched
- A course exercise is not forensic work (Legal Notice §7.8) — but the habits are the ones a responder is judged on

3.5 Eradication and recovery

- Eradication removes the cause: malware deleted, backdoor account disabled, the vulnerability patched, every exposed password changed
    - at BlueFern: the one shared administrator password, on every device that uses it
- Recovery returns the systems: rebuild from a known-good image · restore from a backup that predates the intrusion · verify
- Then heightened monitoring for weeks — attackers come back through the door they know
- Recovery is where Lesson 4 begins: how long it takes is the **RTO** (Recovery Time Objective), how much data it loses is the **RPO** (Recovery Point Objective)

3.6 Post-incident activity — improving the next incident

- Within days: the lessons-learned meeting — what happened and when, how the plan worked, what was missing, which decision would change, which controls would have changed the story
- Output: the incident report + changes to the plan, the detection rules and the controls — the loop back to preparation
- Evidence kept per the retention policy: proceedings or insurance claims may need it a year later

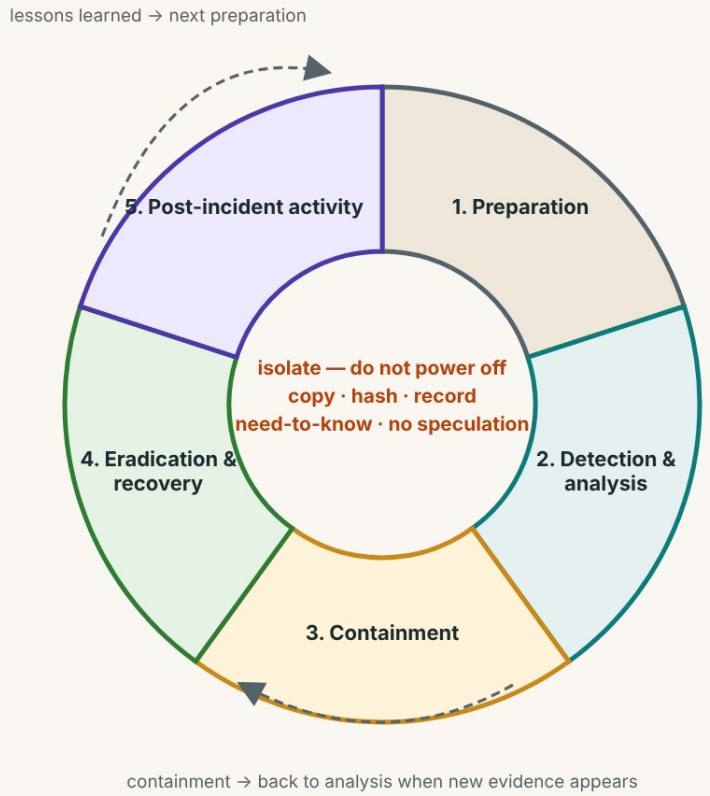
3.7 Who is in the room, and who is told

- Roles: incident lead (timeline) · technical responders · management decision-maker (**CEO** — Chief Executive Officer / **COO**: money, shutdown, ransom) · legal & privacy · communications with one spokesperson
- **PIPEDA** (Personal Information Protection and Electronic Documents Act): report to the **OPC** (Office of the Privacy Commissioner of Canada) and notify the individuals when there is a real risk of significant harm
- Quebec Law 25: notify the **CAI** (Commission d'accès à l'information du Québec) and the persons concerned for a confidentiality incident with a risk of serious injury
- Both laws: a written register of every incident, reported or not
- Payment gateway: written statement within its deadline · cyber-insurer: notify before costs · police: a complaint supports proceedings
- The journalist at T+40 gets a short, factual, legally reviewed statement from the spokesperson
- Two rules: need-to-know inside · no speculation outside

Schematic 3 — The lifecycle, its roles and its evidence rules

Schematic 3 — The incident-response lifecycle with its roles and its evidence rules (Lesson 3)

NIST SP 800-61 Rev. 2 phases, containment named separately (Rev. 3, 2025: Govern · Identify · Protect · Detect · Respond · Recover)



Who is in the room (roles, not names)

Incident lead — coordinates, keeps the timeline
Technical responders — contain, preserve, rebuild
Management decision-maker — money, shutdown, ransom
Legal & privacy — notification duties, counsel
Communications — one spokesperson, facts only

Evidence preservation (3.4)

Disconnect the network, keep the power on
Capture memory and copy the disk before changing anything
Hash every copy (SHA-256); work on copies; keep originals
Chain of custody: who held what, when

Who is told, and by whom (3.7)

Inside: need-to-know only
Payment gateway, insurer: as the contract requires
OPC (PIPEDA): real risk of significant harm → report + notify people
CAI (Quebec Law 25): risk of serious injury → notify CAI + people
Both: keep a register of every incident
Press: a short, factual, legally reviewed statement — no speculation

CS 474 — Computer Security · Class 6 · Cyber.SoHo Educational Hub © 2026 — ALL Rights Reserverd

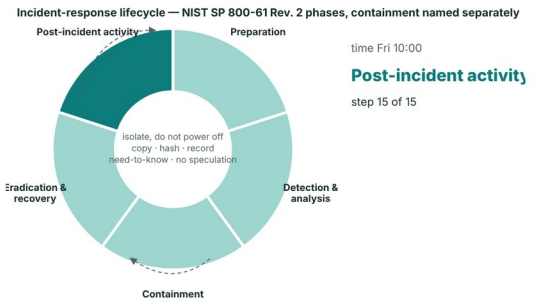
Micro-activity 3 — Which phase is this? (4 min)

- Flash-cards: the five phases one by one — the class says the goal of each in one sentence
- Show of hands — which phase?
  - (a) “Pull the network cable of the file server.”
  - (b) “Write the lessons-learned report.”
  - (c) “Compare the alert's address with the firewall log.”
  - (d) “Restore the database from a backup taken before the intrusion, on a rebuilt server.”

Example 3 — From the alert to the lessons learned

- Task: one BlueFern incident, fifteen steps — the attacker of Example 1 copies the customer table
- 09:40 a developer notices a slow database · 09:55 unknown account svc_backup, export running · 09:58 timeline opened
- 10:10 network interface detached, power stays on · 10:14 memory and disk snapshots, **SHA-256** (Secure Hash Algorithm with a 256-bit digest) hashes · 10:20 account disabled, address blocked
- 12:30 new **VM** (Virtual Machine), restore from the 02:00 backup, **SSH** (Secure Shell) behind the **VPN** (Virtual Private Network), **MFA** (Multi-Factor Authentication) · 15:40 shop back, hourly review
- 16:30 **OPC** (Office of the Privacy Commissioner of Canada) and **CAI** (Commission d'accès à l'information du Québec) notified, customers informed, register entry · Friday: lessons learned, five controls
- Deliverable: the decision-log template (phase · time · action · role · evidence · informed · reason) for Exercise 6.1

Visualization — the lifecycle wheel, roles, evidence and communication



Roles

Incident lead (COO) · Technical responders (IT) · **Management (CEO)** · Legal & privacy · Communications · Developers · Sales / warehouse

Evidence preserved

- 09:55 · Time-stamped screenshots of the process list and the account list
- 09:58 · Incident timeline document (this log)
- 10:05 · Exported alert cards and normalized events, SHA-256 hashes recorded
- 10:10 · Cloud console audit-log entry of the detachment
- 10:14 · Memory image + disk image with SHA-256 hashes; chain-of-custody sheet
- 10:20 · Change log of the firewall and the account
- 11:30 · Copy of the written statement to the gateway
- 12:30 · Build and restore log
- 16:30 · Copies of the notifications; register entry
- Fri 10:00 · Incident report; retained evidence

Informed

- 09:40 · IT staff
- 09:58 · COO
- 10:00 · CEO
- 10:10 · Incident lead
- 10:30 · Staff who need to know
- 11:30 · Payment gateway · legal counsel
- 15:40 · Staff · CEO
- 16:30 · OPC · CAI · 120,000 customers
- Fri 10:00 · Management

Lesson 3 — flash-cards and formative quiz

- FORMATIVE, NOT SUMMATIVE — practice only; nothing is recorded; it does not count toward your grade
- Q1 (**MCQ** — Multiple-Choice Question — one correct answer) — Ransom notes appear on BlueFern's file server. The IT administrator's first action is to pull the server's power plug. According to the lifecycle, …
- Q2 (**MCQ**) — In which phase does the team compare the alert's source address with the firewall log and decide whether the incident is real?
- Q3 (**MCQ**) — Which of the following belongs to the PREPARATION phase?
- Q4 (**MCQ**) — BlueFern confirms that 120,000 customer records with names, addresses and order histories were copied. Under **PIPEDA** (Personal Information Protection and Electronic Documents Act), what triggers the duty to …
- Q5 (**MSQ** — Multiple-Select Question — several correct answers · select 3) — Which actions are part of EVIDENCE PRESERVATION?
- Q6 (**MSQ** · select 2) — Which statements about the ERADICATION and RECOVERY phase are correct?
- Flash-cards: five click-to-flip cards in the module — Name the five steps of the incident-response lifecycle used … · Why “isolate, do not power off”? · What are the three prioritization criteria of **NIST** (National Institute of Standards and Technology) **SP** (Special Publication) 800-61…



Lesson 4 — Recovery and continuity

The 3-2-1 rule · **RPO** and **RTO** · business continuity and disaster recovery — 5 minutes + 2-minute practical

4.1 Backups and the 3-2-1 rule

- A backup: a copy of the data kept separately, from which the data can be restored after loss
- 3-2-1 (**CISA** — Cybersecurity and Infrastructure Security Agency (United States) “Back Up Business Data”; Canadian Centre for Cyber Security **ITSAP**.40.002): three copies · two kinds of media · one off-site
- Modern addition: at least one copy offline or immutable — ransomware encrypts every drive it can see, including the backup drive
- BlueFern today: one **USB** (Universal Serial Bus) drive permanently attached, copied weekly “by whoever remembers”, never tested
  - copies 2 · media 2 · off-site 0 · offline 0 · tested never → the attached drive is encrypted with the server (inject T+30)

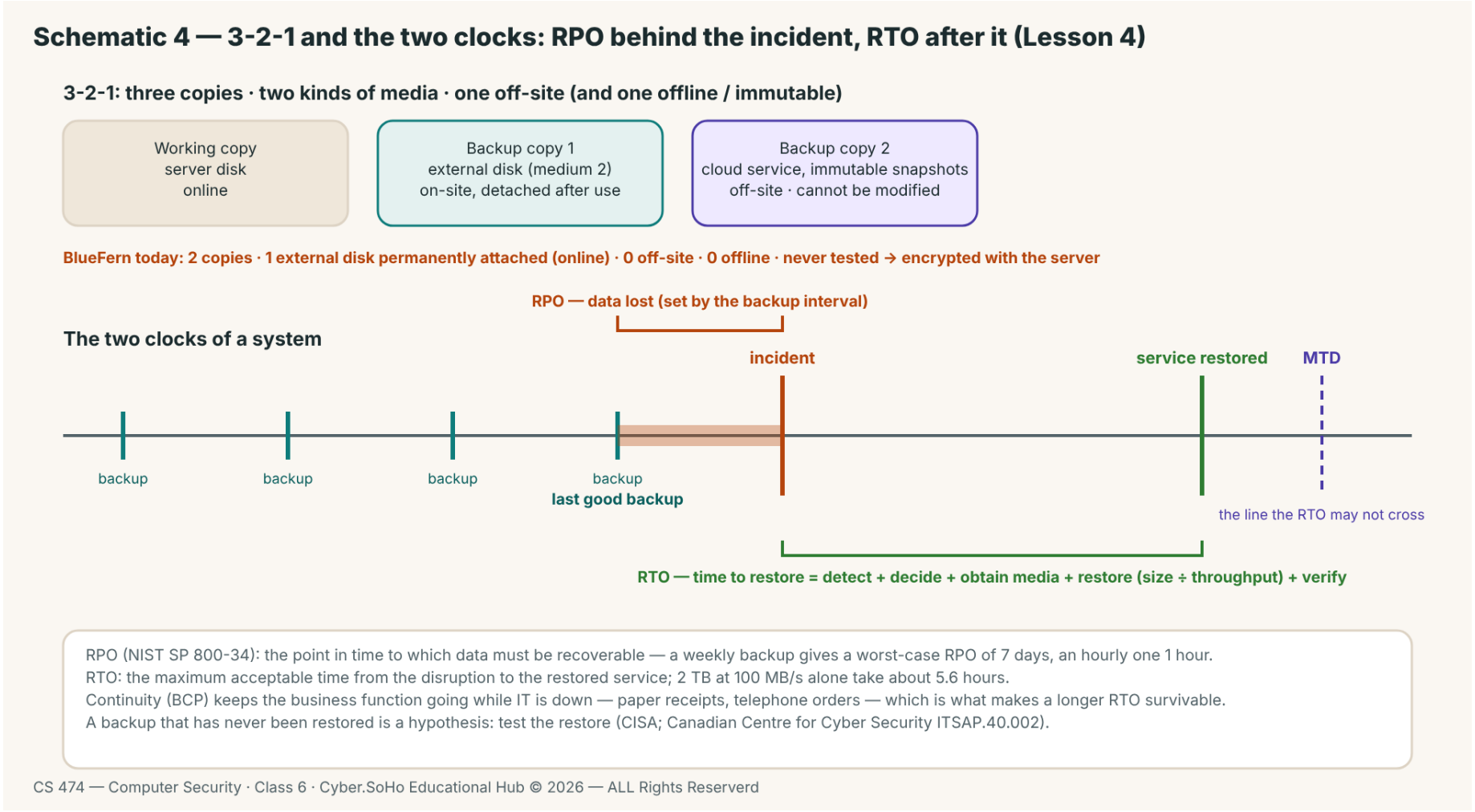
4.2 RPO and RTO — two numbers for every system

- **RPO** (Recovery Point Objective) — Recovery Point Objective (**NIST** — National Institute of Standards and Technology **SP** 800-34): the maximum acceptable data loss, as time — the point in the past to which data must be recoverable
  - set by the interval between backups: weekly → 7 days worst case; hourly → 1 hour
- **RTO** (Recovery Time Objective) — Recovery Time Objective: the maximum acceptable time from the disruption to the restored service
  - the sum of the restore steps: detect and decide + obtain the media + copy back (size ÷ throughput) + verify
  - 2 **TB** (terabyte) at 100 MB/s ≈ 5.6 hours before anyone verifies anything
- **MTD** (Maximum Tolerable Downtime) — Maximum Tolerable Downtime: the longest a business process can be unavailable; the **RTO** must fit inside it
- Decided by the business, paid for by IT; BlueFern's untested weekly drive: **RPO** 7 days, **RTO** unknown — “possibly never”

4.3 Business continuity and disaster recovery

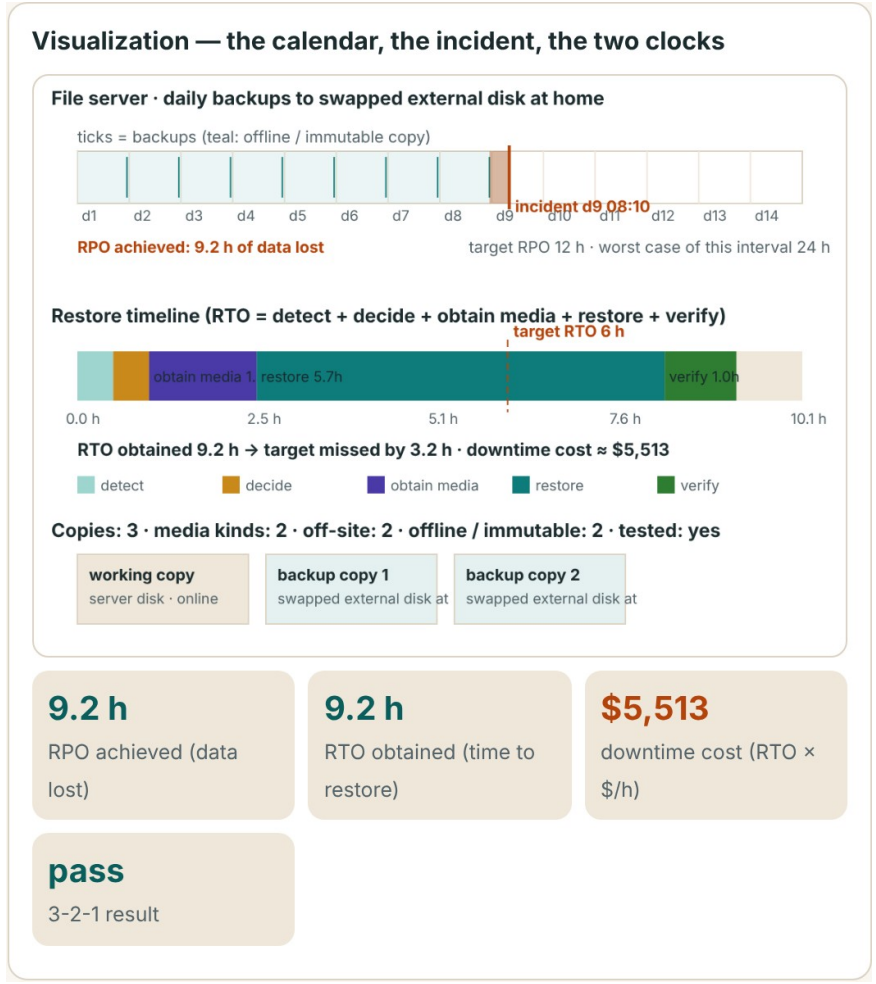
- **DRP** (Disaster Recovery Plan) — the IT plan: how, in which order, by whom, from which copy each system is restored; **RTO** (Recovery Time Objective) and **RPO** (Recovery Point Objective) are its targets
- **BCP** (Business Continuity Plan) — the business plan: how essential functions continue while IT is down — paper receipts, telephone orders, printed picking lists
- Continuity is what makes a long **RTO** survivable
- One obligation both plans share and BlueFern ignores: test the restore — a backup never restored is a hypothesis
- **ITSAP** (IT Security Awareness Publication of the Canadian Centre for Cyber Security).40.002 in three points: keep an offline copy · keep a copy off-site · verify that you can restore

Schematic 4 — 3-2-1 and the two clocks



Micro-activity 4 and Example 4 — the drive that was encrypted too

- Micro-activity (2 min): the file server is backed up to the attached **USB** (Universal Serial Bus) drive every Sunday night; ransomware runs Friday 08:10 and encrypts the server and the drive. **RPO** (Recovery Point Objective) achieved (a) if the drive had been detached after each backup? (b) as things are?
- Example 4 — the planner: fourteen days hour by hour, incident on day 9 at 08:10
  - current state: weekly, attached → total loss, **RTO** (Recovery Time Objective) undefined
  - Design 1: nightly swapped drive taken home → **RPO** 24 h, **RTO** ≈ 9.2 h (passes 3-2-1; a 6-hour target missed by 3.2 h — the **BCP** absorbs it)
  - Design 2: hourly immutable cloud snapshots → **RPO** 1 h, **RTO** ≈ 1.5 h
- Deliverable: the scorecard (system · interval · copies · media · off-site · offline · **RPO** · **RTO** · 3-2-1) = the skeleton of Exercise 6.3



Lesson 4 — flash-cards and formative quiz

- FORMATIVE, NOT SUMMATIVE — practice only; nothing is recorded; it does not count toward your grade
- Q1 (**MCQ** — Multiple-Choice Question — one correct answer) — The customer database is backed up every hour. In the worst case, how much data can be lost — that is, what **RPO** (Recovery Point Objective) does the schedule give?
- Q2 (**MCQ**) — Which part of the 3-2-1 rule does BlueFern's permanently attached **USB** (Universal Serial Bus) drive violate in a way that matters most during a ransomware incident?
- Q3 (**MCQ**) — The file server holds 2 **TB** (terabyte); the restore throughput is 100 megabytes per second; detection and decision take 1.5 hours, fetching the off-site drive …
- Q4 (**MCQ**) — Which statement describes a BUSINESS CONTINUITY measure, as opposed to a disaster-recovery measure?
- Q5 (**MSQ** — Multiple-Select Question — several correct answers · select 3) — Which measures shorten the **RTO** (Recovery Time Objective) of a system?
- Q6 (**MSQ** · select 2) — Which of the following satisfy the OFF-SITE or OFFLINE requirement for BlueFern?
- Flash-cards: five click-to-flip cards in the module — State the 3-2-1 rule and its modern addition. · Define **RPO** and say what determines it. · Define **RTO** and list the steps that add up to it.



Lesson 5 — Risk arithmetic for decisions

AV · EF · SLE · ARO · ALE · is the control worth its cost? — 7 minutes + 5-minute computational + Zen break

5.1–5.2 The five quantities

- Quantitative risk analysis: five quantities, two multiplications — formalized in **FIPS** (Federal Information Processing Standard (United States)) 65 (1979); the quantitative branch of **NIST** (National Institute of Standards and Technology) **SP** (Special Publication) 800-30
- **AV** (Asset Value) — asset value in dollars: replacement + revenue it protects + penalties its loss triggers (customer DB $500,000; file-server data $120,000; web-shop server $40,000; laptop $1,500)
- **EF** (Exposure Factor) — exposure factor: the fraction of **AV** lost in ONE occurrence (fire 100 %; ransomware with partial recovery 75 %; customer-data breach 40 %)
- **SLE** (Single Loss Expectancy) = **AV** × **EF** — the cost of one occurrence
- **ARO** (Annualized Rate of Occurrence) — annualized rate of occurrence: 0.1 = once in ten years; 0.5 = once in two years; 12 = monthly — the least certain number; say so
- **ALE** (Annualized Loss Expectancy) = **SLE** × **ARO** — the expected loss per year, comparable with the annual cost of a control

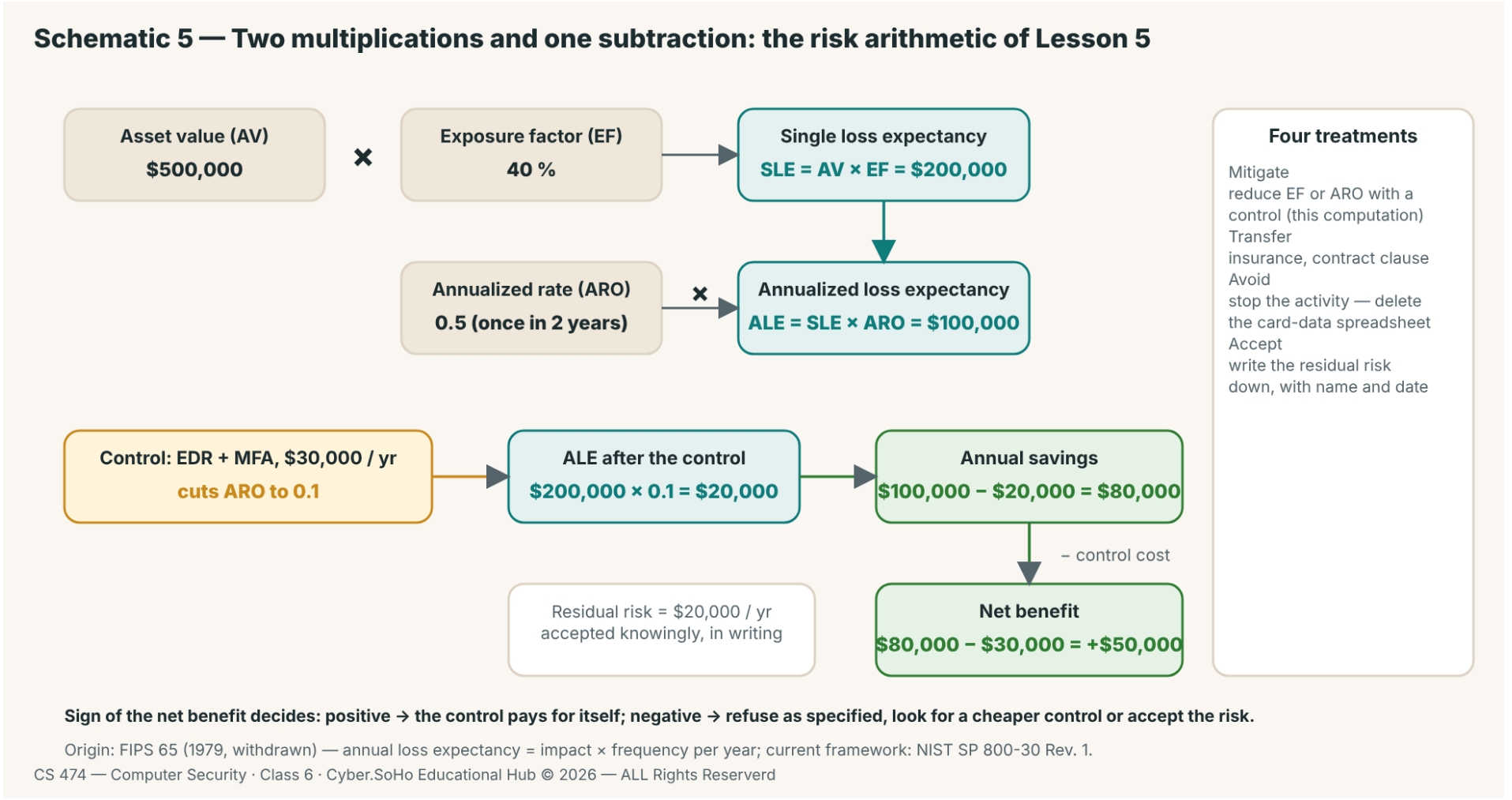
5.3 Is the control worth it? — the customer database

- A control changes a factor: a better backup lowers **EF** (Exposure Factor); **MFA** (Multi-Factor Authentication) + **EDR** (Endpoint Detection and Response) lower **ARO** (Annualized Rate of Occurrence); a scrubbing service lowers both for **DoS** (Denial of Service)
- Net benefit = (**ALE** — Annualized Loss Expectancy before − **ALE** after) − annual cost of the control; positive → the control pays for itself
- Customer database: **AV** (Asset Value) $500,000 · **EF** 40 % · **ARO** 0.5
  - **SLE** (Single Loss Expectancy) = 500,000 × 0.40 = $200,000 · **ALE** = 200,000 × 0.5 = $100,000 per year
- Control: **EDR** on the servers + **MFA** on every account, $30,000 per year, cuts **ARO** to 0.1
  - new **ALE** = 200,000 × 0.1 = $20,000 · savings $80,000 · net benefit $80,000 − $30,000 = $50,000 → worth it
- Residual risk: the $20,000 that remains, accepted knowingly, in writing

5.4 Four treatments — and what the arithmetic can and cannot do

- Mitigate: reduce **EF** (Exposure Factor) or **ARO** (Annualized Rate of Occurrence) with a control (the computation above)
- Transfer: cyber-insurance, a contract clause with the payment gateway
- Avoid: stop the activity — delete the spreadsheet of card expiry dates and last four digits that nobody needs (**EF** → 0)
- Accept: write the residual risk down, with a name and a date, when the control costs more than the loss
- The arithmetic does not predict the year of the breach; it ranks controls on one scale and exposes the $60,000 control for a $5,000 risk
- That ranking is Exercise 6.2 — **LO** (Learning Outcome) 5: evaluate the risks faced by a given computer system

Schematic 5 — Two multiplications and one subtraction



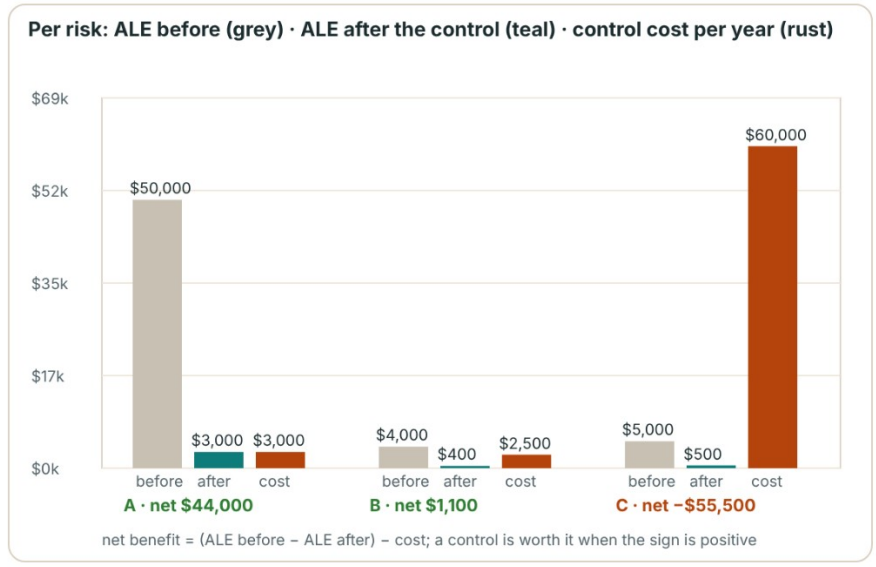
Micro-activity 5 — ALE of the customer database (5 min) + Zen break (2 min)

- Alone, on paper: **AV** (Asset Value) $500,000 · **EF** (Exposure Factor) 40 % · **ARO** (Annualized Rate of Occurrence) 0.5
- (1) **SLE** (Single Loss Expectancy)? (2) **ALE** (Annualized Loss Expectancy)?
- (3) A $30,000-per-year control cuts the **ARO** to 0.1 — new **ALE**, savings, net benefit, decision?
- (4) Same control, but it only cuts the **ARO** to 0.4 — decision?
- Then: stand up, three slow breaths, eyes on a point six metres away, stretch

Example 5 — Three risks on one scale

- A · lost laptop with a customer export: **AV** (Asset Value) $25,000 · **EF** (Exposure Factor) 100 % · **ARO** (Annualized Rate of Occurrence) 2 → **ALE** (Annualized Loss Expectancy) $50,000; encryption + **MFA** (Multi-Factor Authentication) $3,000 → **EF** 6 % → net +$44,000
- B · guest Wi-Fi password on the wall → **POS** (Point of Sale) terminal: **AV** $40,000 · **EF** 50 % · **ARO** 0.2 → **ALE** $4,000; separate networks $2,500 → **ARO** 0.02 → net +$1,100 (marginal; card-brand rules decide)
- C · warehouse scanners offline a day: **ALE** $5,000; a $60,000 monitoring service → net −$55,500 → refuse; accept with a $400 spare access point
- Ranking: A, B, C — one line for the **CFO** (Chief Financial Officer) each
- Deliverable: the register row (risk · **AV** · **EF** · **SLE** · **ARO** · **ALE** · control · cost · new **ALE** · net benefit · rank) = the shape of Exercise 6.2

Visualization — ALE before (grey), ALE after (teal), control cost (rust)



$5,000
SLE = AV × EF

$5,000
ALE = SLE × ARO

$500
ALE after the control

−$55,500
net benefit

Lesson 5 — flash-cards and formative quiz

- FORMATIVE, NOT SUMMATIVE — practice only; nothing is recorded; it does not count toward your grade
- Q1 (**MCQ** — Multiple-Choice Question — one correct answer) — The file-server data is valued at $120,000 and a ransomware incident is estimated to destroy 75 % of its value. What is the **SLE** (Single Loss Expectancy)?
- Q2 (**MCQ**) — With the **SLE** of $90,000 and an **ARO** (Annualized Rate of Occurrence) of 1 (once a year), the **ALE** (Annualized Loss Expectancy) is $90,000. Tested off-site backups costing $8,000 a year cut the **EF** (Exposure Factor) to 10 %. What …
- Q3 (**MCQ**) — An **ARO** of 0.1 means that the threat is expected to occur:
- Q4 (**MCQ**) — BlueFern deletes the old spreadsheet that stored card expiry dates and the last four digits of card numbers. Which risk treatment is this?
- Q5 (**MSQ** — Multiple-Select Question — several correct answers · select 3) — Which statements about the five quantities are correct?
- Q6 (**MSQ** · select 2) — A vendor offers a $60,000-per-year monitoring service that would reduce a risk whose **ALE** is $5,000 to an **ALE** of $500. Which conclusions are correct?
- Flash-cards: five click-to-flip cards in the module — Write the two formulas of quantitative risk analysis. · What is the exposure factor, and what is the annualized rate… · How do you decide whether a control is worth its cost?

Hours 2–3 and Binder Part 6 — summary only

- Exercise 6.1 — Tabletop: “Monday 08:10 — the web shop is down and there are ransom notes on the file server” → incident timeline + decision log (injects revealed one at a time)
- Exercise 6.2 — Risk register: eight BlueFern risks × (**AV** — Asset Value, **EF**, **SLE**, **ARO**, **ALE**); three controls; new **ALE** (Annualized Loss Expectancy); net benefit; ranking — every formula shown
- Exercise 6.3 — Backup and recovery plan: 3-2-1 design; **RPO** (Recovery Point Objective) and **RTO** (Recovery Time Objective) per system (web shop, customer DB, file server, e-mail); restore test schedule
- At home: Easttom Ch. 4 + the **IDS** (Intrusion Detection System) / firewall sections of Ch. 9; finish Part 6
- Binder Part 6 — Incident Response & Risk Register — due Wednesday, November 4, 2026, 23:59
- Why it matters: **SLE** (Single Loss Expectancy) / **ARO** (Annualized Rate of Occurrence) / **ALE** and **RPO** / **RTO** are classic exam computations; the timeline is classic application material (Mid-Term Thu Nov 19)

Links and videos used today (1/2) — standards and guidance

- **NIST** (National Institute of Standards and Technology) **SP** (Special Publication) 800-61 Rev. 3 (2025) and Rev. 2 (2012) — incident handling · **SP** 800-94 — **IDS** (Intrusion Detection System) / **IPS** (Intrusion Prevention System) · **SP** 800-92 — log management
- **NIST SP** 800-34 Rev. 1 — **RPO** (Recovery Point Objective), **RTO** (Recovery Time Objective), **MTD** (Maximum Tolerable Downtime) · **SP** 800-30 Rev. 1 — risk assessment · **FIPS** (Federal Information Processing Standard (United States)) 65 (1979) — origin of the **ALE** (Annualized Loss Expectancy)
- **CISA** (Cybersecurity and Infrastructure Security Agency (United States)) — **DDoS** (Distributed Denial of Service) guide · #StopRansomware Guide · Back Up Business Data (3-2-1) · federal incident response playbooks
- Canadian Centre for Cyber Security — **ITSAP** (IT Security Awareness Publication of the Canadian Centre for Cyber Security).40.003 (incident response plan) · **ITSAP**.40.002 (backups) · **ITSAP**.80.100 (**DoS** — Denial of Service) · **ITSAP**.80.085 (logging)
- **RFC** (Request for Comments — an Internet standards document) 4987 (**SYN** — synchronize flag of a TCP segment flooding) · **RFC** 9293 (**TCP** — Transmission Control Protocol) · **OPC** (Office of the Privacy Commissioner of Canada) (**PIPEDA** — Personal Information Protection and Electronic Documents Act breach reporting) · **CAI** (Commission d'accès à l'information du Québec) and the Quebec Act (Law 25) · Criminal Code s. 342.1

Links and videos used today (2/2) — tools and videos

- Tools named: Suricata · Snort · Zeek (network detection) · Wazuh (host agents, open-source **SIEM**) · Wireshark (packet captures)
- Lesson 1 videos: What Is **SIEM** (Security Information and Event Management)? (IBM Technology, 4:28) · Intrusion Prevention (Professor Messer, 5:13) · What is a Honeypot? (PowerCert, 7:28)
- Lesson 2: **DDoS** (Distributed Denial of Service) Attack Explained (PowerCert, 5:42) · **TCP** (Transmission Control Protocol) **SYN** (synchronize flag of a TCP segment) Flooding (Sourcefire, 8:50) · Denial of Service (Professor Messer, 6:07)
- Lesson 3: Incident Response (Professor Messer, 9:14) · Incident Response Process (Mike Chapple, 11:54) · Digital Forensics (Professor Messer, 9:54)
- Lesson 4: The 3-2-1 Rule (ExplainingComputers, 6:15) · Disaster Recovery Metrics (Mike Chapple, 4:27) · **DR** (Disaster Recovery) vs Backup (IBM Technology, 9:31)
- Lesson 5: Risk Analysis SY0-701 (Professor Messer, 9:13) · Quantitative Risk Assessment (Mike Chapple, 7:11) · Risk Analysis SY0-601 (Professor Messer, 11:01)
- All fifteen checked on October 25, 2026: valid, ≤ 15 min, official channels



Next Thursday: Secrets & Identities

Class 7 — November 5, 2026 — Applied cryptography, authentication and key management · bring a calculator · Binder Part 6 due Wednesday, November 4, 23:59

Cyber.SoHo Educational Hub — From the Industry to the Classroom — Building the IT's Future, Today and Together !

Educational material — Cyber.SoHo / Asen Grozdanov · © 2026 Cyber.SoHo · Legal Notice, Terms of Use and Acceptable Use Policy: https://cyber-soho.github.io/prevmon/00.01.%20cyber.soho%20-%20legal.html